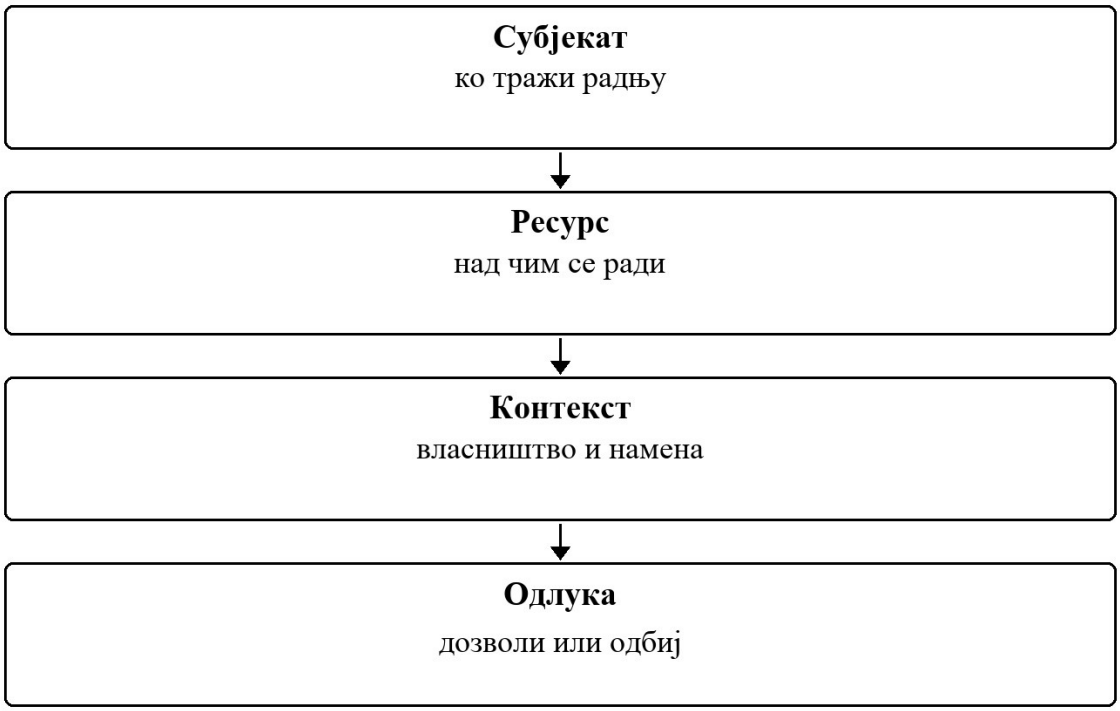
Ауторизација над ресурсом и класификација података

Основе информационе безбедности · 02

Ауторизација има смисла тек када је везана за конкретан ресурс и његов контекст. Корисник може имати легитимну улогу, а ипак не сме да чита, мења или дели баш тај запис. Зато се одлука не завршава провером типа ендпоинта или назива улоге.

Класификација података даје исти језик власницима, развоју и операцијама. Када систем зна колико је податак осетљив, може да примени одговарајући приступ, приказ, чување и евиденцију без ослањања на нечије сећање.



Слика 1. Зашто познавање адресе ресурса не значи право приступа

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

2.1 Одлука мора имати контекст

Класификација података даје исти језик власницима, развоју и операцијама. Када систем зна колико је податак осетљив, може да примени одговарајући приступ, приказ, чување и евиденцију без ослањања на нечије сећање.

- Провера права укључује субјект, радњу, ресурс и његову припадност.
- Одбијање не треба да открива садржај нити постојање туђег осетљивог ресурса.
- Класификација није етикета за документацију, већ улаз у правила руковања подацима.

Питање за дискусију

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

2.2 Како се ова тема види у развоју

За сваку значајну операцију тим формулише и позитиван и негативан сценарио. Негативан сценарио проверава да правилно пријављен корисник не може да заобиђе власништво променом идентификатора или позивом Програмски интерфејс-ја ван интерфејса.

Честе грешке које треба препознати

- Провера улоге без провере односа према конкретном ресурсу.
- Филтрирање листе у клијенту без исте провере на серверу.
- Снижавање класификације без образложења и трага промене.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

2.3 Пример: исправна улога, погрешан запис

Два члана тима имају исту улогу и обојица могу да прегледају захтеве. Један мења идентификатор у адреси захтева и долази до туђег записа. Систем који проверава само улогу сматра захтев дозвољеним, иако се променио најважнији део контекста: однос корисника према конкретном ресурсу.

- Одлука укључује идентитет, тражену радњу, ресурс и припадност ресурса одговарајућем домену или власнику.
- Исти принцип важи за Програмски интерфејс позив, извоз података и позадинску обраду, не само за екран који корисник види.
- Одговор на одбијени приступ треба да буде користан клијенту, али не сме да открије податке о заштићеном запису.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

2.4 Дизајнерска одлука: податак носи обавезе

Класификација не говори само колико је податак важан. Она утиче на начин приказа, извоз, дељење, чување и брисање. Када те последице нису јасно везане за класификацију, сваки нови екран или интеграција мора поново да погађа како треба руковати информацијом.

- Класификација има пословно значење које сви чланови тима тумаче на исти начин.
- Правила за приказ и извоз треба да буду строжа када последице грешке расту.
- Власник податка одговара за оправданост промене класификације, а систем чува траг те промене.

2.5 Како знамо да је ауторизација потпуна

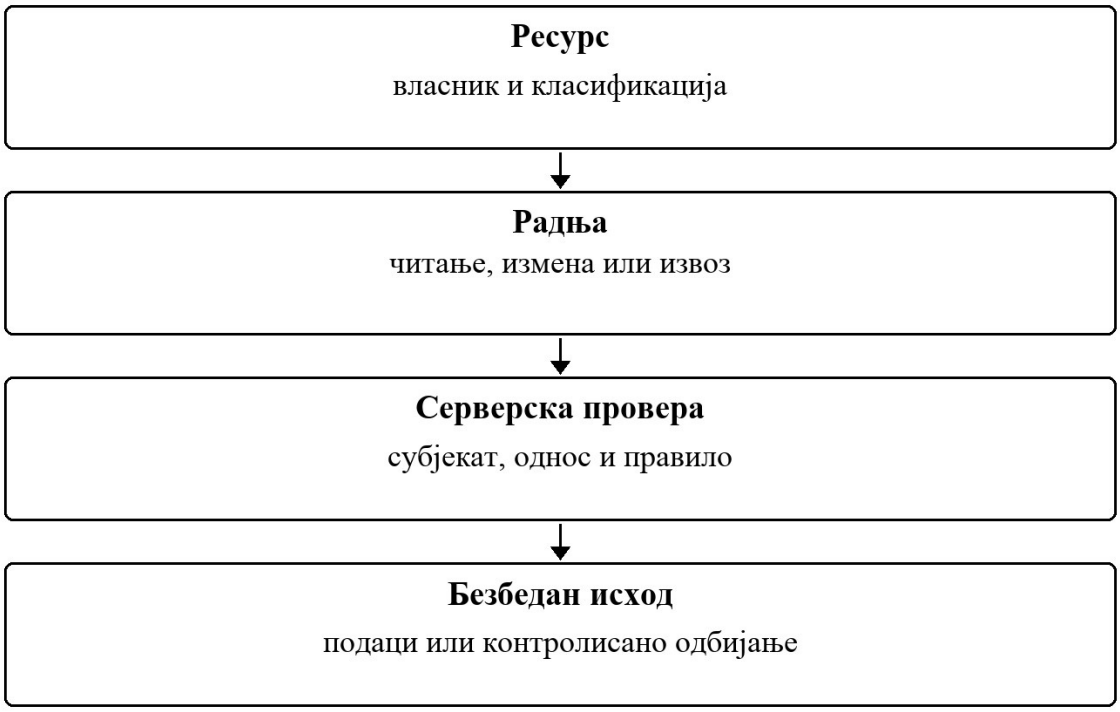
Приступ треба проверити кроз стварну границу система, а не само кроз кориснички интерфејс. То значи да директан Програмски интерфејс захтев, позадински процес и извоз не могу прескочити исто правило. Негативни тестови зато нису додатак после имплементације, већ најјаснији опис границе приступа.

- Систем једнако штити ресурс када се захтев пошаље ван стандардног екрана.
- Одбијени захтев не враћа детаље који помажу да се мапирају туђи подаци.
- Промена класификације и промена власништва остављају довољно трага за касније преглед.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

2.6 Шема заштите једног ресурса



Слика 2. Шема заштите једног ресурса

Идентификатор у адреси не представља право приступа. Однос субјекта према ресурсу проверава се на серверу.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

2.7 Нивои провере приступа

Табела 1. Ниво и Шта проверава

Ниво	Шта проверава	Зашто није довољан сам
Пријава	Идентитет субјекта.	Не говори шта субјекат сме да уради.
Улога	Општи скуп одговорности.	Не зна однос према конкретном запису.
Ресурс	Власништво, припадност и класификацију.	Мора се комбиновати са радњом и политиком.
Контекст	Време, стање и пословно оправдање.	Може променити закључак за исту улогу.

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

2.8 Животни циклус податка

Заштита података не завршава се у тренутку читања. Исти податак пролази кроз креирање, употребу, дељење, чување и уклањање. Свака фаза поставља друго питање о дозвољеном приступу и потребном трагу.

1. При креирању се одређују власник и класификација.

2. При коришћењу се проверава сврха и опсег приступа.

3. При дељењу се проверава граница поверења и минимални скуп података.

4. При чувању и уклањању примењују се рокови чувања и правила ревизијског евидентирања.

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Ауторизација над ресурсом и класификација података". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

2.9 Извршиви пример

`ResourceReadPolicy` проверава дозволу, власништво и класификацију конкретног записа. Провера се извршава на серверу за сваки захтев.

Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.

```
cd examples/oib-dotnet/vezba-02-resurs-klasifikacija
dotnet run --project src/Oib.Vezba02.ConsoleUi
dotnet test Oib.Vezba02.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Корисник погађа идентификатор туђег записа.
Тестови	`ResourceReadPolicyTests`, `ReadResourceHandlerTests`
Доказ	`ResourceAccessAuditEntry` садржи исход и стабилан код одлуке.

Задатак уз пример

Увести радњу измене записа: мења га само власник, без обзира на `records:read:any`. Додати нову политику и случај употребе поред постојећих, без мењања `ResourceReadPolicy`.